

AGENT-FIRST DEPENDENCY SECURITY

WARDEN

Every dependency change becomes a
verified transaction.

```
$ npm install expres █
```



THE ATTACK SURFACE

The package is the payload.



THE CORE LOOP

Resolve, verify, diff, scan, score: before anything runs.

~/project

• LIVE

▶▶ SKIP

```
$ warden check acme-http@1.0.1
resolving acme-http@1.0.1
✓ integrity verified    sha512
! release diff         postinstall added
! provenance           attestation removed
! code                 process.env → raw IP
BLOCK acme-http@1.0.1  risk 100 / 100
exit 20 · install never started
```

BLOCKED BEFORE ANY SCRIPT RAN

THE CORE LOOP

You typed one package. Warden plans the whole graph, then makes you approve the one part that wants to execute.

~/project

• LIVE

▶▶ SKIP

```
$ warden plan -- npm install esbuild
```

```
✓ resolving the prospective dependency graph · 27 6.1s
```

```
✓ vetting 27 changed packages · 27/27 19.6s
```

```
Warden plan: npm install esbuild
```

```
+ 26 transitive packages · 27 of 27 analyzed · 26 platform binaries
```

```
NEEDS_APPROVAL esbuild@0.28.1 has a postinstall script
```

```
warden approve-script esbuild@0.28.1 --hook postinstall
```

```
one approval, bound to that version, tarball, hook and script body
```

```
the script still never runs: the approval authorizes the install, not the code
```

27 PACKAGES RESOLVED AND ANALYZED, ONE APPROVAL REQUIRED, SCRIPTS SUPPRESSED UNTIL IT IS GRANTED

ONE POLICY, FOUR MANAGERS

Four managers, four different safety settings, set once.

~/project

• LIVE

▶▶ SKIP

```
$ warden policy
```

```
Policy compiled for npm
```

```
Intent  scripts approved · min age 1d · exotic sources block · downgrades block
```

```
Native settings
```

```
  .npmrc  ignore-scripts = true
```

```
  .npmrc  min-release-age = 1
```

```
  .npmrc  allow-git, allow-remote, allow-directory, allow-file = none
```

```
Not natively supported
```

```
  block version downgrades · npm has no native downgrade policy
```

```
Enforced by warden regardless
```

```
  a downgrade is visible in the plan as a version move
```

STATE THE INTENT ONCE; WARDEN WRITES EACH MANAGER'S OWN KEYS, NAMES WHAT THAT MANAGER CANNOT DO, AND ENFORCES THE REST ITSELF

THE CONTROL THAT DOES NOT TRUST YOUR LAPTOP

A shim is convenience. The receipt is what CI refuses to merge without.

~/project

• LIVE

▶▶ SKIP

```
$ warden verify
```

```
WARDEN VERIFY wtxn_4c1d1f3c55dac2e468c53ff3
```

```
ok graph matches receipt the installed graph is the one the receipt was issued for
```

```
ok policy digest the receipt was issued under the plan still on disk
```

```
ok result the transaction was applied
```

```
ok artifact coverage 27 artifacts carry a verdict
```

```
$ warden ci --require-transaction-receipt
```

```
the dependency graph changed but no warden transaction receipt was committed
```

```
exit 20 · the pull request does not merge
```

AN ABSOLUTE PATH OR A CONTAINER WALKS PAST THE SHIM; NOTHING WALKS PAST A PULL REQUEST THAT WILL NOT MERGE

LIVE PRODUCT

The same gate, run backward across what's already installed.

~/project

• LIVE

▶▶ SKIP

```
$ wnpm doctor
```

```
auditing 3 direct dependencies against OSV advisories
```

```
high      acme-json@2.1.0    prototype pollution  (fixed in 2.1.4)
```

```
critical  acme-http@1.0.0    request smuggling   (fixed in 1.0.1)
```

```
BLOCK    acme-http@1.0.1    install-script added, exfiltration, provenance downgrade
```

```
UNFIXABLE acme-http: the official fix fails the supply-chain gate
```

```
verified  acme-json@2.1.4 · install ok · test ok · applied
```

```
1 of 2 issues fixed · exit 10
```

THE OFFICIAL FIX GETS REJECTED WHEN THE RELEASE ITSELF IS COMPROMISED

LIVE PRODUCT

Claims from the prompt, checked against the diff.

~/project

• LIVE

▶▶ SKIP

```
$ warden intent check
prompt "add rate limiting, keep the retry logic, log every rate-limited request"
3 claims extracted · 2 files changed
✓ delivered    add rate limiting                api-client.ts:1-39
✓ preserved    retry logic untouched
✗ dropped      log every rate-limited request  no matching change
! scope creep pagination.ts, 55 lines, never requested
! hallucinated axios.instance.throttle, not exported by axios
BLOCK 3 findings
exit 20 · diff does not match the prompt
```

FLAGS DRIFT BEFORE THE PR MERGES

THE PRODUCT SURFACE

One trust layer. Every workflow.

Every verb resolves to the same contract: allow, warn, or block.

check

vet a package

plan

decide the graph

apply

install with a receipt

install

vet, then install

ci

vet changed deps

doctor

audit & repair

intent

diff vs. prompt

policy

compile the rules

detect

map workspace

init

wire guardrails

fix

agent handoff

log

observe safely

shims for npm, pnpm, yarn, bun, npx, and bunx · pick one with `--npm`, `--pnpm`, `--yarn`, `--bun` · protect blocks, observe just records

AGENT-FIRST GUARDRAIL

Your agent gets evidence, a fix, and a finish line.

structured handoff

• LIVE

» SKIP

```
$ warden fix
wrote .warden/handoff.json
finding  expres@0.0.5 · typosquat
evidence 1 edit from express · postinstall added
fix      replace expres with express
verify   warden ci --reporter agent
launch   codex exec "Read .warden/handoff.json..."
$ codex exec "Read .warden/handoff.json and apply the
fix"
updated  package.json · expres → express
$ warden ci --reporter agent
verdict  allow · exit 0
```

detect

→

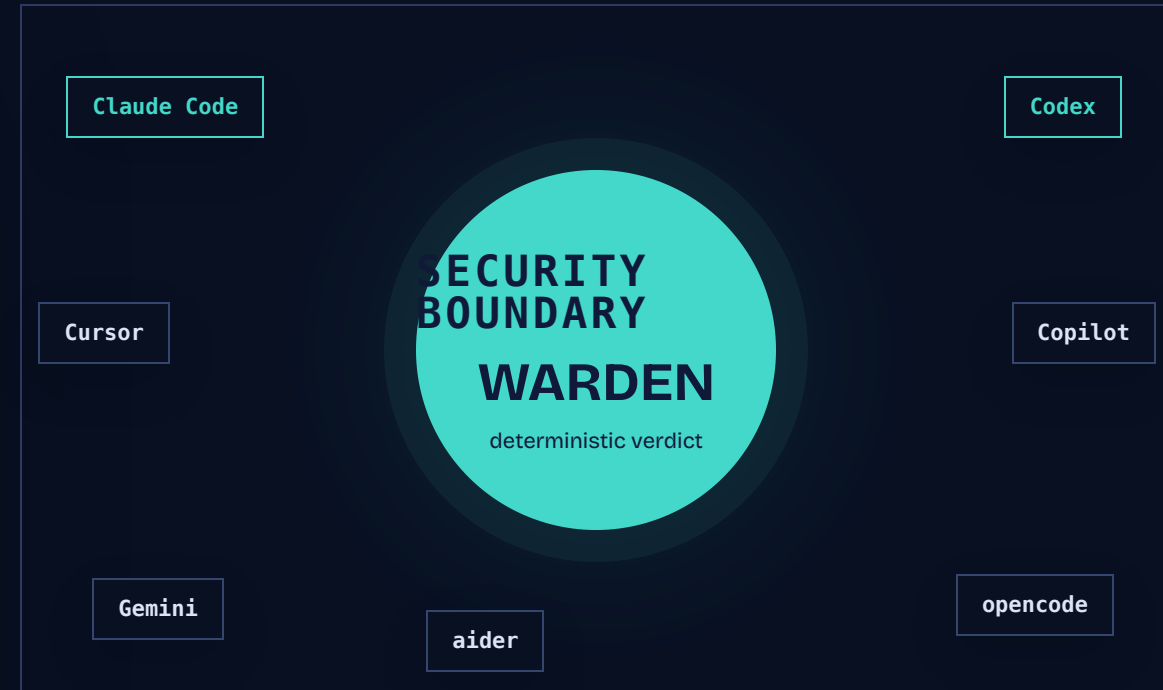
handoff

→

fix

→

verify clean



THE OUTCOME

Keep the workflow.

Add the checkpoint.



EVIDENCE

Sources

01 [CVE Program metrics](#)

02 [Sonatype 2026 report](#)

03 [USENIX package hallucinations](#)

04 [OSV advisory database](#)

Figures checked July 14, 2026.

